

IMMO BURUNDI

COMPLETE USER ROLES, PERMISSIONS & ACCESS-CONTROL SPECIFICATION

Real Estate Marketplace & Brokerage Platform

Project	IMMO BURUNDI
Document	Complete User Roles, Permissions & Access-Control Specification
Purpose	Defines every user role in the platform and what each role can see, create, edit, approve, publish, export, delete and manage

Table of Contents

1. CORE ACCESS-CONTROL PRINCIPLE	4
2. ROLE HIERARCHY	4
3. MAIN ADMIN	5
4. CHIEF / EXECUTIVE ADMIN	8
5. DEPARTMENT HEAD	9
6. PROVINCIAL ADMIN	9
7. COMMUNE ADMIN	10
8. REGIONAL SUPERVISOR	10
9. VERIFICATION OFFICER	11
10. ACCOUNTANT	12
11. MODERATOR	13
12. CUSTOMER SUPPORT OFFICER	13
13. MARKETING / PROMOTION OFFICER	14
14. FIELD AGENT	14
15. PROPERTY OWNER / SELLER	15
16. LANDLORD	16
17. BUYER	16
18. TENANT / RENTAL APPLICANT	16
19. INVESTOR	17
20. GENERAL REGISTERED CLIENT	17
21. PUBLIC VISITOR / GUEST	17
22. PERMISSION CATEGORIES	18
23. DATA-SCOPE PERMISSIONS	20
24. STAFF PRIVACY	20
25. PROPERTY VIEWER PRIVACY	21
26. FINANCIAL PRIVACY	22
27. VERIFICATION PRIVACY	22
28. APPROVAL SEPARATION	23
29. DUAL APPROVAL FOR SENSITIVE ACTIONS	23
30. ROLE ASSIGNMENT RULES	23
31. TEMPORARY PERMISSIONS	24
32. PERMISSION OVERRIDES	24
33. ACCOUNT STATUS	25
34. SECURITY REQUIREMENTS	25

35. AUDIT REQUIREMENTS 25

36. RECOMMENDED ROLE/PERMISSION MATRIX 26

37. FRONTEND BEHAVIOR 27

38. API AUTHORIZATION 27

39. RECOMMENDED DATABASE STRUCTURE FOR RBAC 28

40. FINAL NON-NEGOTIABLE RULES 29

41. DEVELOPER IMPLEMENTATION REQUIREMENT 29

Document purpose:

This document defines every user role in the IMMO BURUNDI platform, what each role can see, create, edit, approve, publish, export, delete, and manage.

This specification applies to:

- Public website
- Android application
- iOS application
- Agent application/interface
- Administration dashboard
- Backend/API
- Accounting system
- Verification system
- Reporting system
- Audit system

1. CORE ACCESS-CONTROL PRINCIPLE

IMMO BURUNDI must use server-side Role-Based Access Control (RBAC).

Frontend visibility alone is NOT security.

If a user does not have permission, the backend API must reject the request even if the user manually calls the API.

Every sensitive operation must verify:

1. User identity
2. Account status
3. Assigned role
4. Permission
5. Geographic scope, if applicable
6. Department scope, if applicable
7. Ownership of the record, where applicable
8. Approval requirements
9. Audit requirements

2. ROLE HIERARCHY

The recommended hierarchy is:

Level 0 — Platform Owner

1. Main Admin

Level 1 — Executive / Department Management

2. Chief / Executive Admin
3. Department Head

Level 2 — Regional / Geographic Management

4. Provincial Admin
5. Commune Admin

6. Regional Supervisor

Level 3 — Operational Staff

- 7. Verification Officer
- 8. Accountant
- 9. Moderator
- 10. Customer Support Officer
- 11. Field Agent
- 12. Marketing / Promotion Officer

Level 4 — External Platform Users

- 13. Property Owner / Seller
- 14. Landlord
- 15. Buyer
- 16. Tenant / Rental Applicant
- 17. Investor
- 18. General Client / Registered User

Level 5 — Public

- 19. Public Visitor / Guest

3. MAIN ADMIN

Role

The Main Admin is the platform owner and has unrestricted access to the entire IMMO BURUNDI system.

This is the highest authority.

Access

Main Admin can access:

- All properties
- All users
- All agents
- All staff
- All departments
- All provinces
- All communes
- All verification records
- All financial records
- All payments
- All commissions
- All promotion orders
- All rental applications
- All visit bookings
- All analytics
- All reports

- All documents
- All audit logs
- All system settings

Main Admin permissions

Users

- Create user
- View user
- Edit user
- Suspend user
- Activate user
- Delete/deactivate user
- Reset account
- Change role
- Assign permissions
- Revoke permissions
- View account history
- View login/security history

Staff

- Create staff
- Edit staff
- Suspend staff
- Activate staff
- Assign department
- Assign geographic area
- Assign role
- Grant additional permissions
- Revoke permissions
- View staff private information
- View staff performance
- View staff activity
- View staff audit history

Properties

- Create
- Edit
- Review
- Verify
- Approve
- Reject
- Request correction
- Publish
- Unpublish
- Archive
- Mark sold

- Mark rented
- Restore
- Delete
- Change visibility
- Change verification status
- Change featured status
- View sensitive owner information

Financial system

Main Admin has complete access to:

- Verification payments
- Promotion payments
- Sales commissions
- Rental commissions
- Refunds
- Adjustments
- Payment records
- Revenue
- Expenses, if implemented
- Financial reports
- Transaction history
- Accounting reports
- Export functions

Reports

Can generate:

- Daily reports
- Weekly reports
- Monthly reports
- Quarterly reports
- Annual reports
- Revenue reports
- Commission reports
- Verification reports
- Promotion reports
- Agent performance reports
- Property reports
- User reports
- Traffic/view reports

Audit logs

Main Admin alone has unrestricted access by default.

Can view:

- Who performed an action
- What action was performed
- Record affected

- Old value
- New value
- Date/time
- IP/device information where collected
- Login history
- Permission changes
- Financial changes
- Property changes

System

- Configure platform
- Configure currencies
- Configure languages
- Configure fees
- Configure commissions
- Configure verification fees
- Configure promotion packages
- Configure rental rules
- Configure visit capacity rules
- Configure notification settings
- Configure integrations
- Configure storage
- Configure security settings

4. CHIEF / EXECUTIVE ADMIN

Purpose

Senior management role above department heads.

Can:

- View operational dashboards
- View properties
- View agents
- View departments
- View performance reports
- Review major operational activity
- Approve selected high-level operations if explicitly assigned
- View aggregated financial reports if authorized
- View strategic reports

Cannot automatically:

- View private staff information
- View full audit logs
- Change Main Admin
- Change platform ownership
- Access unrestricted financial data
- Change system security

- Grant themselves permissions
- View private client information unless required and authorized

Important

A Chief must not automatically inherit Main Admin access.

Sensitive information must require explicit permission.

5. DEPARTMENT HEAD

Department Heads manage their specific department.

Examples:

- Head of Verification
- Head of Sales
- Head of Rentals
- Head of Accounting
- Head of Operations
- Head of Marketing

Permissions

Can:

- View department dashboard
- Manage department tasks
- Assign department tasks
- Review department records
- Monitor department staff
- Approve permitted department operations
- Generate department reports
- View department performance

Cannot automatically:

- View all staff private information
- View all financial information
- View all audit logs
- Change user roles outside department
- Modify system-wide settings
- Access unrelated departments
- Access Main Admin security settings

6. PROVINCIAL ADMIN

Manages operations within an assigned province.

Can:

- View properties in assigned province
- Review listings
- Manage local agents
- Review local verification requests

- Manage local clients
- Review local applications
- Manage local visits
- View provincial statistics
- Generate provincial reports

Cannot:

- Access other provinces unless authorized
- View global financial information
- Change Main Admin settings
- View unrestricted staff information
- Modify global system configuration

7. COMMUNE ADMIN

Manages operations within an assigned commune.

Can:

- View commune properties
- Review local listings
- Manage assigned agents
- Review local applications
- Manage local visits
- View local statistics
- Handle local operational tasks

Geographic restriction

The backend must enforce:

```
user.commune_id == record.commune_id
```

unless the user has a broader permission.

8. REGIONAL SUPERVISOR

Supervises field operations across an assigned geographic area.

Can:

- View assigned agents
- Monitor agent activity
- Review submitted properties
- Track verification tasks
- Monitor field activities
- View agent performance
- Assign field tasks
- Review operational reports

Cannot:

- Publish properties unless explicitly authorized
- Modify accounting records

- Access global financial data
- Change user roles
- Access private staff information outside authorized scope

9. VERIFICATION OFFICER

Responsible for property/document verification.

Can:

Properties

- View submitted properties
- Review property information
- Review uploaded documents
- Request corrections
- Record verification findings
- Upload verification evidence
- Mark verification stage
- Recommend Verified
- Recommend Partial
- Recommend Not Verified

Documents

Can review:

- Land Title
- T.O.P
- Owner ID
- Sale Agreement
- Other permitted documents

Verification

Can:

- Accept verification request
- Assign verification
- Start verification
- Complete verification
- Record notes
- Generate verification report
- Generate verification code
- Update verification status

Cannot automatically:

- Change accounting records
- Issue refunds
- Modify platform settings
- Publish property independently unless separately authorized
- Delete verification history

- Delete audit records

Critical rule

Verification Officer cannot remove historical verification records.

Corrections must create an audit trail.

10. ACCOUNTANT

Accounting must be separated into controlled categories.

Accountant permissions

Verification accounting

- View verification payments
- Confirm payment
- Record payment
- Reconcile payment
- Generate verification payment report

Promotion accounting

- View promotion payments
- Confirm promotion payment
- Reconcile promotion payment
- Generate promotion report

Sales commissions

- View sales commission records
- Record commission
- Confirm commission
- Reconcile commission

Rental commissions

- View rental commission records
- Record commission
- Confirm commission
- Reconcile commission

Refunds

Depending on assigned permission:

- View refund request
- Review refund
- Recommend refund
- Process refund

Actual high-value refunds should require additional approval.

Accountant cannot:

- Change property verification
- Publish properties

- Change user roles
- Access staff private data without authorization
- Delete financial history
- Modify audit logs

11. MODERATOR

Responsible for content quality and platform compliance.

Can:

- Review property descriptions
- Review photos
- Review titles
- Review inappropriate content
- Flag suspicious listings
- Request correction
- Hide content
- Report users
- Moderate comments/reviews if implemented
- Review reported content

Cannot:

- Approve ownership verification
- Modify accounting
- Access private financial data
- Publish verified properties unless separately authorized
- Delete audit history

12. CUSTOMER SUPPORT OFFICER

Handles client questions and support requests.

Can:

- View client profile
- View support history
- View relevant property information
- Respond to clients
- Create support tickets
- Update ticket status
- Assist with bookings
- Assist with applications
- Escalate issues

Privacy restriction

Customer Support should only see information necessary to resolve the request.

Sensitive financial and staff information remains restricted.

13. MARKETING / PROMOTION OFFICER

Manages property promotion.

Can:

- View promotion requests
- Create promotion packages
- Process promotion orders
- View promotion status
- Manage featured listings
- Schedule featured campaigns
- View promotion statistics
- Contact property owners regarding promotions

Cannot:

- Modify accounting totals directly
- Alter payment history
- Verify property ownership
- Change legal verification status

14. FIELD AGENT

Agents are operational users who collect and submit property information.

Can:

Properties

- Create property
- Save draft
- Upload photos
- Upload documents
- Enter owner information
- Enter property information
- Record GPS
- Submit property
- Edit property when correction requested
- View own submitted properties
- Track status

Clients

- Create client lead
- Record client contact information
- Record property enquiry
- Schedule/assist with visits where permitted

Agent dashboard

Can see:

- Own listings

- Submitted listings
- Approved listings
- Rejected listings
- Corrections required
- Deals
- Performance
- Commission information applicable to agent

Cannot:

- Publish property
- Mark property Verified independently
- Approve own property
- Modify verification result
- Modify accounting records
- Access another agent's private records unless authorized
- Access global financial dashboard

Conflict-of-interest rule

An agent must never be able to approve or verify their own submitted property.

15. PROPERTY OWNER / SELLER

External user who owns or represents a property.

Can:

- Create account
- Create property listing
- Upload property documents
- Submit property
- Edit own draft
- View own property
- Track verification
- Request verification
- Purchase promotion
- View own enquiries
- Receive messages
- Receive visit requests
- View analytics allowed to owners
- Update contact information

Cannot:

- Mark property verified
- Publish property as verified
- Edit verification records
- Access another owner's data
- Access internal staff information

16. LANDLORD

Can:

- Create rental listing
- Edit own rental listing
- Upload documents
- Request verification
- View rental enquiries
- View rental applications
- Review applications
- Manage visit requests
- Contact applicants
- Purchase promotion
- View permitted property analytics

17. BUYER

Buyer account.

Can:

- Search properties
- Save favorites
- Compare properties if implemented
- Contact agent/owner through permitted channels
- Send enquiries
- Book visits
- Track visits
- Apply for purchase
- View own requests
- Manage profile
- Receive notifications

Cannot:

- Access private owner data unless intentionally disclosed
- View internal verification documents that are restricted
- Access accounting
- Modify property data

18. TENANT / RENTAL APPLICANT

Can:

- Search rentals
- Save favorites
- Contact agent/landlord
- Book visits
- Submit rental application
- Track application

- Upload required documents
- Update application where permitted
- Cancel own request where allowed
- Receive notifications

Cannot:

- View other applicants
- View private landlord information beyond permitted contact channels
- Modify property information
- Access internal verification records

19. INVESTOR

Investor is an extended client role.

Can:

- Search properties
- Filter investment opportunities
- Save properties
- Contact agents
- Request information
- Book visits
- Submit enquiries
- View permitted market/property information
- Manage own profile

Additional investor tools can be added later.

20. GENERAL REGISTERED CLIENT

A general client account can:

- Search properties
- Save favorites
- Contact agents
- Contact owners through permitted channels
- Book visits
- Submit enquiries
- Receive notifications
- Manage own profile
- View own activity

21. PUBLIC VISITOR / GUEST

No account required.

Can:

- Browse public listings
- Search

- Filter
- View property pages
- View public property information
- View public verification status
- View public photos
- View public approximate location
- Contact through permitted public channels
- Share listings
- View public agent profiles

Cannot:

- Book visits
- Submit rental applications
- Access private documents
- View owner private phone
- View internal verification records
- Access dashboards

Login should be required for actions involving personal information or bookings.

22. PERMISSION CATEGORIES

The backend should use granular permissions instead of relying only on role names.

Recommended permission format:

```
resource.action
```

Examples:

Users

- `users.view`
- `users.create`
- `users.update`
- `users.suspend`
- `users.delete`
- `users.change_role`

Properties

- `properties.view`
- `properties.create`
- `properties.update`
- `properties.submit`
- `properties.review`
- `properties.approve`
- `properties.reject`
- `properties.publish`
- `properties.unpublish`
- `properties.archive`
- `properties.delete`

- `properties.view_sensitive`

Verification

- `verification.view`
- `verification.create`
- `verification.assign`
- `verification.review`
- `verification.update`
- `verification.approve`
- `verification.reject`
- `verification.generate_code`
- `verification.view_history`

Accounting

- `accounting.view`
- `accounting.create`
- `accounting.update`
- `accounting.reconcile`
- `accounting.refund`
- `accounting.export`

Promotion

- `promotion.view`
- `promotion.create`
- `promotion.update`
- `promotion.approve`
- `promotion.activate`
- `promotion.cancel`

Reports

- `reports.view`
- `reports.create`
- `reports.export`
- `reports.financial`
- `reports.global`

Analytics

- `analytics.view`
- `analytics.property`
- `analytics.agent`
- `analytics.global`

Staff

- `staff.view`
- `staff.view_sensitive`
- `staff.create`
- `staff.update`
- `staff.suspend`

- `staff.permissions`

Audit

- `audit.view`
- `audit.export`

System

- `system.settings`
- `system.integrations`
- `system.security`
- `system.roles`
- `system.permissions`

23. DATA-SCOPE PERMISSIONS

Permissions must also define which records a person can access.

Recommended scopes:

GLOBAL

Everything.

Only Main Admin by default.

DEPARTMENT

Only records belonging to the user's department.

PROVINCE

Only records within assigned province.

COMMUNE

Only records within assigned commune.

TEAM

Only records belonging to assigned team.

OWN

Only records created/owned by the user.

ASSIGNED

Only records specifically assigned to the user.

PUBLIC

Only information intentionally exposed publicly.

24. STAFF PRIVACY

This is mandatory.

A staff record should contain:

- Staff ID

- Photo
- Full name
- Phone
- Email
- Address
- Department
- Role
- Province
- Commune
- Employment status
- Start date
- Emergency contact, if collected
- Internal notes
- Performance information
- Login/security information

Main Admin

Can access everything.

Chief

Only sees sensitive staff information if explicitly authorized.

Department Head

Normally sees operational staff information required for management.

Provincial/Commune Admin

Only sees staff relevant to their geographic responsibility.

Other employees

Cannot browse private staff records unless specifically authorized.

25. PROPERTY VIEWER PRIVACY

A property owner or agent may see analytics such as:

- Total views
- Unique visitors
- Favorites
- Shares
- WhatsApp clicks
- Phone clicks
- Enquiries
- Visit bookings

However:

Simply viewing a property must NOT reveal the viewer's identity to the owner or agent.

For example, an owner should NOT receive:

"John Doe, phone 79xxxxxx, viewed your property."

merely because John opened the listing.

Identity can become visible when the user intentionally:

- Sends an enquiry
- Sends a message
- Books a visit
- Submits a rental application
- Submits a purchase request
- Explicitly provides contact information

26. FINANCIAL PRIVACY

Financial permissions must be separately controlled.

Main Admin

Full financial access.

Accountant

Accounting records necessary for assigned accounting responsibilities.

Department Head

Only financial information explicitly authorized.

Agent

Only their own applicable commissions/payments.

Owner/Landlord

Only their own payments and transactions.

Public users

No internal financial information.

27. VERIFICATION PRIVACY

Internal verification documents should not automatically become public.

Public users may see:

- Verification status
- Verification date
- Verification badge
- Verification reference where appropriate
- Limited verification summary

They should not automatically see:

- Internal verification notes
- Internal reviewer comments

- Private identity documents
- Sensitive ownership documents
- Internal fraud/suspicion notes
- Staff comments

28. APPROVAL SEPARATION

Critical operations should use separation of duties.

Property submission

Agent → submits

Verification

Verification Officer → reviews

Publication

Authorized Admin → publishes

Payment

Accountant → confirms

Refund

Accountant/requester → requests

Authorized approver → approves

Own-property restriction

The person who creates/submits a property should not approve or verify the same property.

29. DUAL APPROVAL FOR SENSITIVE ACTIONS

The system should support configurable two-person approval for:

- Large refunds
- Major financial adjustments
- Manual commission changes
- Deleting critical records
- Changing verification status after publication
- Changing system-wide fees
- Changing commission percentages
- Creating privileged administrator accounts

Main Admin may override these controls when necessary, but the override must create an audit record.

30. ROLE ASSIGNMENT RULES

Only authorized administrators can assign roles.

Recommended default:**Main Admin**

→ Can assign all roles.

Chief

→ Can assign selected operational roles only if Main Admin grants permission.

Department Head

→ Can request or assign limited department permissions if authorized.

Other staff:

→ Cannot assign themselves roles.

Users must never be able to modify their own role through the frontend.

31. TEMPORARY PERMISSIONS

The system should support temporary permissions.

Example:

A Verification Officer normally cannot publish listings.

Main Admin can grant:

```
properties.publish
```

for:

- Start date
- End date
- Specific geographic scope
- Specific department

When the expiration date arrives, permission automatically disappears.

Every temporary permission must be logged.

32. PERMISSION OVERRIDES

A user can receive additional permissions without changing their primary role.

Example:**Primary role:**

```
Verification Officer
```

Additional permission:

```
reports.export
```

This allows the user to export reports without making them an Accountant or Admin.

The backend must record:

- Who granted permission
- Permission granted
- Reason

- Date granted
- Expiration date
- Who revoked it

33. ACCOUNT STATUS

Every user account should support:

- Pending
- Active
- Suspended
- Disabled
- Locked
- Deleted/Deactivated

Suspended users cannot perform normal authenticated operations.

Existing audit history must remain preserved.

34. SECURITY REQUIREMENTS

The backend must enforce:

- RBAC
- Permission checks
- Geographic scopes
- Department scopes
- Ownership checks
- Authentication
- Session expiration
- Refresh-token security
- Rate limiting
- Failed-login protection
- Audit logging
- Sensitive-data protection

Never rely on:

- Hidden buttons
- Frontend routes
- Mobile-app restrictions
- JavaScript-only checks

35. AUDIT REQUIREMENTS

Every sensitive action should generate an audit event.

Examples:

- User created
- User suspended
- Role changed

- Permission granted
- Permission revoked
- Property approved
- Property rejected
- Property published
- Property unpublished
- Verification completed
- Verification changed
- Payment confirmed
- Refund processed
- Commission changed
- Financial record modified
- Sensitive document accessed
- Report exported

Audit records should include:

- User ID
- Role
- Action
- Resource
- Resource ID
- Timestamp
- IP where collected
- Device/session where collected
- Previous value where applicable
- New value where applicable
- Reason where required

Audit records must not be editable by ordinary staff.

36. RECOMMENDED ROLE/PERMISSION MATRIX

Role	Properties	Verification	Accounting	Users	Reports	Staff	Audit
Main Admin	Full	Full	Full	Full	Full	Full	Full
Chief	Assigned	Assigned	Authorized	Limited	Strategic	Limited	Limited
Department Head	Department	Department	Department	Department	Department	Department	Limited
Provincial Admin	Province	Province	Limited	Province	Province	Province	Limited
Commune Admin	Commune	Commune	Limited	Commune	Commune	Commune	Limited
Regional Supervisor	Assigned	Assigned	No	Assigned	Assigned	Assigned	No
Verification Officer	Review	Full assigned	No	Limited	Verification	No	Assigned
Accountant	Limited	No	Assigned/Full	No	Financial	No	Financial
Moderator	Content	No	No	Reports	Content	No	No
Support Officer	View	Limited	No	Support	Support	No	No
Marketing Officer	Promotion	No	Promotion view	Leads	Promotion	No	No
Field Agent	Own/Assigned	Submit	Own commission	Leads	Own	No	Own activity

Role	Properties	Verification	Accounting	Users	Reports	Staff	Audit
Owner/Seller	Own	Request	Own payments	Own	Own analytics	No	Own
Landlord	Own	Request	Own payments	Own	Own analytics	No	Own
Buyer	View	Public	Own transactions	Own	Own	No	Own
Tenant	View	Public	Own transactions	Own	Own	No	Own
Investor	View	Public	Own transactions	Own	Own	No	Own
Client	View	Public	Own	Own	Own	No	Own
Guest	Public	Public	None	None	Public	None	None

Note: "Full", "Assigned", "Own", etc. are data scopes, not just UI visibility.

37. FRONTEND BEHAVIOR

The frontend should dynamically display functions according to permissions.

For example, if a user does not have:

```
properties.publish
```

the Publish button should not appear.

However, hiding the button is only a usability feature.

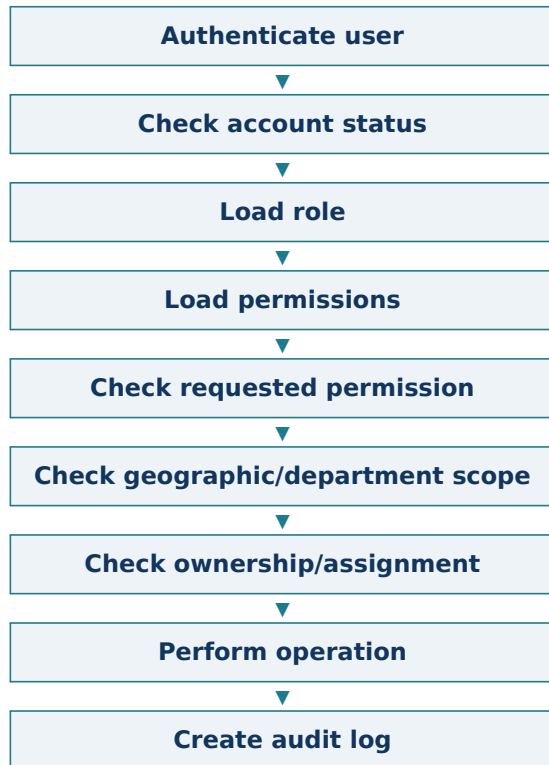
The backend must still reject:

```
POST /properties/{id}/publish
```

if the user lacks the permission.

38. API AUTHORIZATION

Every protected endpoint should execute authorization middleware.

Example logic:

39. RECOMMENDED DATABASE STRUCTURE FOR RBAC

The backend should use separate tables for:

users

User identity and account.

roles

Role definitions.

permissions

Individual permissions.

role_permissions

Permissions assigned to roles.

user_roles

Roles assigned to users.

user_permissions

Individual permission overrides.

permission_scopes

Global, province, commune, department, own, assigned, etc.

user_scopes

The geographic/organizational scope assigned to each user.

audit_logs

Complete activity history.

staff_profiles

Internal employee information.

departments

Department definitions.

provinces

Province definitions.

communes

Commune definitions.

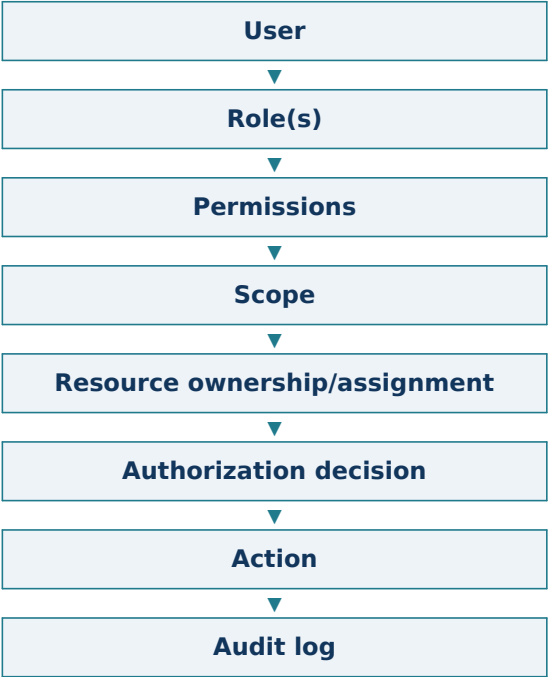
40. FINAL NON-NEGOTIABLE RULES

1. Main Admin has unrestricted access.
2. No other role automatically receives Main Admin privileges.
3. Roles and permissions must be enforced on the backend.
4. Geographic restrictions must be enforced server-side.
5. Department restrictions must be enforced server-side.
6. Ownership restrictions must be enforced server-side.
7. Agents cannot publish their own properties.
8. Agents cannot verify their own properties.
9. Verification Officers cannot modify accounting.
10. Accountants cannot modify verification results.
11. Moderators cannot modify financial records.
12. Owners cannot modify verification status.
13. Clients cannot access internal staff information.
14. Staff private information is restricted by default.
15. Property viewers remain anonymous to owners/agents unless they intentionally interact.
16. Financial information is private by default.
17. Internal verification documents are private by default.
18. Audit logs cannot be deleted or modified by ordinary users.
19. Permission changes must themselves be audited.
20. Temporary permissions must automatically expire.
21. Sensitive actions should support dual approval.
22. A user cannot grant themselves permissions.
23. A user cannot change their own role.
24. Deleted/deactivated users must retain historical audit references.
25. Every sensitive operation must be traceable to a specific user.

41. DEVELOPER IMPLEMENTATION REQUIREMENT

The developer should implement the permission system as a central authorization service/middleware, rather than scattering role checks throughout individual pages.

The architecture should support:



This architecture must be designed so that IMMO BURUNDI can add future roles and permissions without rewriting the entire application.